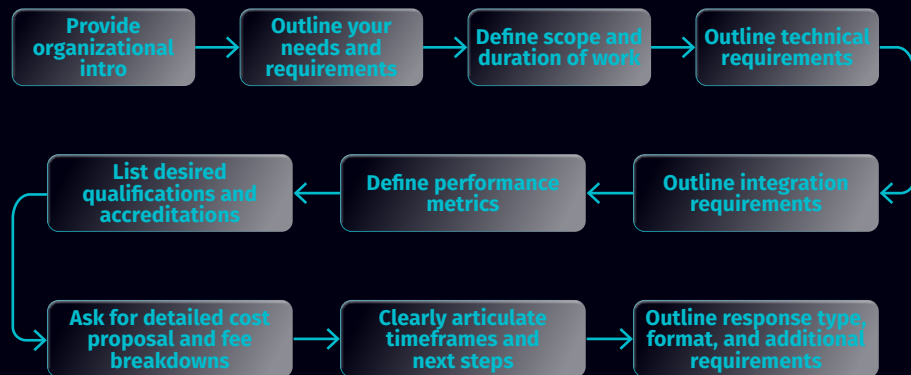


Detection Engineering: Know the Data. Know the Threat. Craft the Detection.

This poster was created by Kathryn Hedley primarily based on the research and knowledge of Nick Mitropoulos in authoring SEC555. ©2026 SANS Institute. All Rights Reserved.
CD_SEC555_Detection_01-26

Definitions

- **Attacker dwell time**—The amount of time attackers are there before we detect them
- **Detection engineering**—Creating appropriate content for monitoring tools/solutions, to enable the identification of potential attack indicators, as early as possible
- **EPS**—*Events Per Second*—a key metric used to size log aggregation systems—should not be used as the solo metric
 - Rough conversion from Events Per Day (EPD) to EPS: divide the EPD by 86,400 (seconds in a day)
- **MSSP**—*Managed Security Service Provider*—a company that offers third-party services in managing and monitoring systems to prevent, detect, and respond to cyberattacks
 - When choosing an MSSP, follow the process:
 - *Define scope and objectives*—Identify actual organizational needs
 - *Draft a Request For Proposal (RFP)*
- **MSSP evaluation**—Ask the MSSP questions to determine their experience, capabilities, ways of working, and breach history
- **Selection**—Use a scoring system—common criteria include capability, cost, and SLA adherence
- **Onboarding**—Define key contacts, provide documentation, deploy agreed solutions and processes, test alert criteria, escalation protocols, and tool integrations, define reporting frequency and meeting cadence, provide staff training, and switch over to full operations
- **SIEM**—*Security Information and Event Management solution*—a platform that collects, aggregates, and analyzes data from various sources, to provide a comprehensive view of an organization's security posture, and assist in effective and timely detection, investigation, and response to security incidents
- **Event (also known as an event of interest)**—NIST SP 800-61 (Computer Security Incident Handling Guide), defines this as "any observable occurrence in a system or network that warrants attention, potentially indicating a security incident"
- **Alert**—Potentially unwanted or unauthorized event—this really means you don't know and you need to investigate
- **Incident**—NIST SP 800-61 (Computer Security Incident Handling Guide), defines an incident as "a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices"



Data Collection Strategies

Three main strategies for data collection

Input-driven

- Collect everything
- **Pros:** Allows for historical data analysis to establish patterns and trends
- **Cons:** Slow and expensive

Output-driven

- Collect only what you know you need
- **Pros:** Makes deployment and analysis easier and cheaper
- **Cons:** May miss something you did not know you needed

Hybrid

- Start collecting everything but constantly trim to filter out low-value events
- **Pros:** Cheaper to maintain than input-driven but you still have historical data
- **Cons:** Requires ongoing tuning and can be expensive

Determining SIEM Architecture Requirements

Calculate EPS

- When in doubt, lab it out
- Consider growth and peaks
- Build-in ability to scale up or down within a contract

Determine Storage Requirements

- Use a PoC solution
- Consider: compression, de-duplication, raw vs adjusted data, storage formats

Decide Data Retention

- May vary with compliance and internal policies
- Plan for fast (hot) and slow (cold) storage
- Rule of thumb = key events on fast storage for 7-30+ days
- Beware of cloud or third-party restrictions



Requirements Discovery

Requirements can come from various teams, including:

- **SOC**—Provide requests for rules to assist in obtaining alerts, expressing attacker activity and signs of intrusion. As the immediate consumers of detection rules, they have a unique perspective to help in creating and improving detections.
- **Threat hunting**—As this team do their best to identify and eradicate attackers they assume are already present, they have a unique perspective to help in creating and improving detections.
- **Threat intelligence**—May be using internal, external or both categories of tools, to provide actionable intelligence to other operational teams, which can be translated to detections for malicious activity.
- **Incident response**—Responding to incidents provides opportunities to identify gaps in defenses and therefore how detections can be improved.
- **Penetration testing**—Can identify holes in detection tools, which can then be addressed.
- **Malware Analysis**—Can provide feedback about malicious samples they've analysed, and how they can potentially be identified.

Requirements should meet the criteria:

- **Coverage**—What is this detection about? What specific attacker techniques or procedures does it cover?
- **Durability**—How long is this detection expected to be effective for?
- **Complexity**—How much effort will the detection require to create and test it?
- **Confidence**—How sure are you that alerts being generated by a detection actually depict hostile activity?
- **How noisy is it**—How many false positives are generated? Can tuning reduce noise?
- **Actionable content**—Does a security analyst know what to do, after this detection triggers?
- **Attacker cost**—What lengths does the attacker need to go to, to leverage a given exploit?



Triage

Criteria to triage incoming requests and identify which ones to turn into detections:

- **Detection priority (low, medium or high)**—How important is this detection for your environment?
- **Threat severity (low, medium or high)**—What happens if this threat isn't detected?
- **Organizational impact (low, medium, or high)**—What is the damage to the organization if this detection isn't created?
- **Organizational relevance (low, medium or high)**—Is this detection useful to the organization?
- **Exploit in the wild exists (yes/no)?**—Is there an active exploit available?
- **If exploit exists, is it easy to execute (low, medium, high)?**—How easy is it for an attacker to use an existing exploit to breach your environment or access data?
- **Required time (low, medium, high)**—How straightforward is it to develop and deploy a detection?



Investigation

The goal of this phase is to enable you to proceed to developing a detection by focusing on identifying what is required to make the detection successful.

Indicator Types:

- **Behavioral** detections usually require a lot of time and effort to be created and deployed but can exhibit low numbers of false positives.
- **Statistical** detections are based on patterns of traffic/activities, which often require baselining to compare with.
- **Static** detections may have shorter lifespans so it can be used for tactical countermeasures.

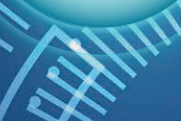
Consider the deployment of Honeypots—decoy data meant for an attacker to steal that can then be monitored—to assist with early threat detection, provide TTP insight, and delay attackers.

Detection Engineering Life Cycle*

*Practical Threat Detection Engineering by: Megan Roddie, Jason Deyalsingh, Gary J. Katz



Deployment



Requirements Discovery



Triage



Investigation



Development



Testing



Deployment

More complicated rule creation, find more advanced threats

Faster rule creation, more tactical applicability

Behavioral

Statistical

Static

From Logs to Alerts

Collect

Aggregate

Store

Alert

Analyze

Log Collection Options

- **Agent-based**—Use a built-in agent that is supported by the target system, a SIEM tool's agent or third-party software. Agents can be feature-rich, potentially including parsing capabilities, delivery to multiple locations, rotation, buffering or encryption of log data, monitoring and alerting. Both open source and commercial agents are available.
 - *Advantage*—Agent does a lot of processing on the target before data is sent back
 - *Disadvantage*—Maintenance, upgrades, and troubleshooting are required
- **Agentless**—Gather logs using native tools on the target, such as Windows Event Forwarding—requires admin privileges
 - *Advantage:* Installing and configuring an agent is not required, so this is quicker to deploy and manage
 - *Disadvantage:* Limited capability, requires inbound firewall rules to be set up
- **API integration**—Use of tools' APIs to collect logs—some level of configuration is required
- **Cloud native**—Cloud providers have their own ways of collecting logs, such as Azure's Azure Monitor Agent (AMA)
- **Others**—For example, writing scripts for collection or collecting local files from systems—these are typically case-specific use cases

Aggregation

Aggregation of logs pulls information together so it can be filtered and enriched. This may include parsing, filtering, or enriching the data before it is sent to one or more final destinations.

Log Enrichment

- Forward (DNS name to IP address, based on A records) and reverse (IP address to DNS name, based on PTR records) DNS lookups can assist with filtering and provide useful context.
- Tagging top sites based on the likes of the Cisco Umbrella Top 1 Million Sites allow the most queried domains based on passive DNS usage to be filtered out: <https://s3-us-west-1.amazonaws.com/umbrella-static/index.html>
- Threat Intelligence Feeds add context to log data.
- The Open Threat Exchange, developed by AlienVault, can also be used with custom IoCs and is provided with OTX Endpoint Security: <https://otx.alienvault.com>
- Malware Information Sharing Platform (MISP): <https://www.misp-project.org>

Message Brokers

A Message Broker may be added to the Aggregation stage (placed between Aggregators), to act as a lifeguard. Without a Broker, the aggregator may crash or drop logs:

- If the aggregator is sent too many logs
- If the backend storage needs to be taken offline
- If the backend storage is getting overloaded with search queries, and log ingestion slows down

With a Broker, the backend log aggregator will only retrieve logs from the broker when it is ready to do so, and if the storage system starts to get overloaded, the backend aggregator will hold off on delivering logs until it is back to normal performance.

You need to verify how this works.
Many custom applications and newer log agents natively have built-in capabilities to buffer logs in memory or to disk, so a Broker may not be needed.

Log Storage

Logs must remain manageable, so the storage system must have the performance and architecture capabilities to perform quick searching—consider:

- **Indexing**—Allow your tool to be able to search and retrieve information you need.
- **Search queries**—Allow use of search queries to dig into the data and obtain information.
- **Redundancy**—If your primary storage solution fails, there must be an alternative, to provide continuous access to data.
- **Performance**—Provide an acceptable retrieval speed for searching. Should performance be an issue, consider separating compliance and tactical logs. This allows processing of less important logs on slower disks.
- **Volume**—Determine how much data you need to store and for how long. Retention periods may be different for different types of data or different legal requirements; this must be accommodated.

Alerting and Analysis

Discovery is best when a combination of techniques are used, such as:

- **Deny lists**—Searching for known bad. Can be helpful, only if you know what "bad" looks like. However, deny lists tend to be easily bypassed as attackers adapt to being blocked.
 - Note: Consider the use of exclusions to allow penetration testers to do their job, while alerting on attacker behaviors.
- **Allow lists**—Ignoring known good and searching and alerting on everything else. This can be difficult to maintain as you need good knowledge of the environment and systems. The upside is that anything not included in the list will alert, and you might catch a zero day.
- **Long tail analysis**—Assumes high-frequency events are normal conditions and identifies events of least occurrence. Outliers may be indicative of malicious activity. Does not work well with small datasets; the more data you have, the better this technique works.
- **Anomaly detection**—Identify events that are not normal, mostly using a baseline of the environment, to alert on deviations. This requires establishing a very good baseline, although this can and should be adapted over time.

Common SIEM Detection Techniques

- **Fuzzy Searching**—Search for company look-alike domains in inbound emails, potentially used for phishing
 - Using this technique on simple mail transfer protocol (SMTP) logs will produce fewer false positive results than DNS or HTTP due to how genuine typos are handled.
- Common techniques used by attackers:
 - *Character omission*—removing one or more characters from the URL
 - *Character insertion*—Inserting one or more characters into the URL
 - *Character replacement*—Combination of insertion and omission where an existing character gets replaced
 - Homograph attack uses valid Unicode that matches expected ASCII.
 - *Character transposition*—Character positions get swapped
- **Randomness checking**—Attackers commonly use randomness to evade filters. A randomness check can be performed against a domain name in logs. This involves mathematically calculating the frequency of characters. The lower the score, the higher the likelihood of randomness. A good tool for this: <https://github.com/MarkBaggett/freq>
- **Spike Monitoring**—Monitor for dramatic changes in email volume.
 - Spikes in volume from outside sources can be indicative of a phishing campaign. This method works best by combining with an allow list approach to reduce false positives.
- Dramatic changes in outbound email volume may be indicative of SMTP data exfiltration or Command and Control.
- **Impersonation**—Look for key employee names within non-corporate email addresses.
 - It is common for attackers to act as key executives in an organization (known as whaling).

- **Suspicious user agents**—Monitor SMTP user agents for potentially suspicious strings. Know normal to find abnormal.
- **Odd email sources**—There should be a finite list of authorized email sources, so check for odd SMTP traffic not on an allow list.
- **Newly created domains**—Attacker domains are typically registered a few hours or days prior to use for nefarious purposes. This method works best by combining with an up-to-date allow list to reduce false positives.
- **Frequent NXDOMAIN DNS responses**—Domain not found; a high number of occurrences may indicate malware is using a domain generating algorithm (DGA). NXDOMAIN in itself is normal, but the frequency/volume of occurrences is typically low.
- **Fast flux**—Constantly changing IP addresses for a domain. This method is used by attackers to avoid detection using IP address deny lists. Look for:
 - Repetitive DNS queries with TTLS < 300
 - DNS queries with a response count > 12
 - Persistent callbacks for botnet control
 - Known fast flux IP addresses and name servers in TI feeds
- **Searching for known malicious IoCs**—Use TI feeds and previous analysis to monitor for known attacker/malware domains.
- **DNS tunneling detection**—Uses DNS to communicate directly with an attacker's external DNS server.
 - Limit which external DNS servers can be used
 - Monitor for large number of requests from a single IP address
 - Monitor for use of special DNS query types (e.g., TXT records)
 - Monitor NXDOMAIN records
 - Monitor the size of outbound DNS queries (i.e., more than 40 characters)
 - Monitor domain name entropy (look for high degree of randomness; indicative of encoded data)

- **Monitoring for naked IP address requests**—Filter out expected mismatches in DNS request/response and IP address, to detect malware or policy violations:
 - Cached DNS resolution (a DNS request will only be required when the cache expires)
 - Microsoft IP addresses
 - Content Delivery Network networks
 - Root DNS server IP addresses
 - Hardcoded IP addresses
 - DNS over HTTPS
 - Occasional vendor connections
- **Unauthorized proxies**—Look for any X-Forwarded-For (XFF) field entries not on an allow list. This contains the originating system's source IP address and is used to identify web proxies.
- **URL length threshold violations**—URL lengths can be very large during an attack. A possible starting size to monitor is 140–150 characters.
- **Unknown user agents**—Monitor for atypical user agent strings for that system and common browsers.
- **Unusual TLS certificates**—Search for certificates not issued by a trusted root certificate authority. A self-signed certificate should never be trusted as it was issued and used by the same entity. More than 90% of all SSL certificates are issued by five certificate authorities
 - Let's Encrypt
 - Sectigo
 - DigiCert Group
 - GlobalSign
 - GoDaddy Group
- **Unusual TLS certificate fields**
 - A certificate with a common name missing a period is abnormal as this should show a domain name.
 - Search for illegitimate country codes not on an allow list.
 - Certificates with the bare minimum of fields populated may indicate malware.

HTTP

Common Web Server Log Formats

NAME	FIELD	EXAMPLE ENTRY	DEFAULT FORMAT FOR
Common Log Format	• Remote host address • Remote logname (usually unused/blank and shows "-") • Authenticated user. If user isn't authenticated, this shows "-" • Timestamp • Request (method, resource, and protocol) • HTTP response status code • Response size in bytes	10.0.0.101 - Nick [10/Mar/2025:13:55:36 -0700] "GET /index.html HTTP/1.0" 200 2326	Apache • access.log = default log of requests to the web server • error.log = record of errors or abnormalities
Combined Log Format	Common Log Format + referrer + user agent	10.0.0.107 - - [06/Mar/2025:06:59:26 -0800] "GET /favicon.ico HTTP/1.1" 404 209 "http://10.0.0.110/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/54.0.2840.87 Safari/537.36"	Nginx • access.log = default log of requests to the web server • error.log = record of errors or abnormalities
W3C Extended	• Date and time of request • Server IP address (s-ip) • Client request method (cs-method) • Requested resource file (cs-uri-stem) • Query string (cs-uri-query) • Server port (s-port) • Username (dash = unauthenticated) (cs-username) • Remote requesting client IP address (c-ip) • User-agent string (csuser-agent) • Referrer (csreferrer) • HTTP status code (sc-status) • Windows sub-status code (sc-substatus) • Win32 status code (sc-win32-status) • Time taken to process request (milliseconds) (time-taken) Note: Does not specify timezone—recorded in UTC	2025-03-06 14:24:48 192.168.1.10 GET /favicon.ico - 80 - 192.168.1.30 curl/8.8.0 - 404 0 2 2	IIS

Common HTTP Fields Explained

FIELD	DESCRIPTION
Source IP address	Remote client IP the request originated from
Source port	Source port of the remote client making the request
Destination IP address	Destination web server
Destination port	Destination web server's port
Method	Request method used (GET, POST, etc.)
Virtual host	The specific website being accessed
Referrer	URL of the referring page that was used
URI	Requested resource path
User-agent	Denotes what the client used to access the page (e.g., URL or Mozilla Firefox)
Request bytes	Request length in bytes
Response bytes	Response length in bytes
Status code	HTTP server status code
Sub-status code	Used for more detailed error information
User	Username of the requesting user (if they have authenticated to access a resource)
Proxy	IP address of the proxy device that sent the request to the server
Server name	Web server's hostname

CATEGORY	DESCRIPTION
100–199	Informational responses
200–299	Successful responses
300–399	Redirection messages
400–499	Client error responses
500–599	Server error responses

Common HTTP Request Methods

RECORD TYPE	DESCRIPTION
CONNECT	Allows tunneling through another endpoint such as a proxy, commonly used in proxied HTTPS connections
DELETE	Remove a resource from a web server
GET	Retrieve data—the most common request sent to a web server
HEAD	Retrieve HTTP headers only—useful to test a webpage's operation or check web server information
OPTIONS	List out all the VERBS supported for a given site—doesn't retrieve data, but only supported methods from the server (e.g., GET, POST) and other supported capabilities
PATCH	Allows for partially updating an object (in contradiction to PUT, which only allows replacing the entire resource with a new one of your choice)
POST	Submit data, such as a form
PUT	Create or update a specified resource—most often seen when uploading a file to a server (commonly used by API services but often dropped by web application firewalls)
TRACE	Take input and send it back to the client for debugging

HTTP Response Status Codes

CIS Critical Security Control #1 focuses on knowing all authorized and unauthorized devices. You cannot protect what you don't know about. Identify everything—find unauthorized devices.

- **Active detection**—Source device interacts with the target by sending packets and waiting for responses. Scans increase network resources and may disrupt services, but can identify devices with medium-high accuracy.
- **Passive detection**—No interaction with end devices, so no impact on network resources. Existing network traffic is commonly used to identify machines, but with low accuracy since some machines may not be generating traffic at that time.

Authenticated vs. Unauthenticated Scanning

AUTHENTICATED	UNAUTHENTICATED
Uses credentials to scan a system	Doesn't require any credentials
Provides highly accurate information	Accuracy is low
Presents lower rates of false positives	False positives can be very high due to the lack of machine visibility
Can identify a lot of detail	Only gets limited detail
Can degrade system performance	Minimal impact on performance
Great fit for regulatory compliance scenarios	Limited use in a regulatory compliance scenario
Can lead to issues if credentials are compromised	Can be easily blocked by firewalls or IPS
Requires credential management and maintenance	No credential overhead is present since the scan doesn't need them

Network Access Control (NAC)

The most common device authorization methods use:

- **Organizationally Unique Identifier (OUI)**—The first six hexadecimal characters of a MAC address, associated with the device vendor. Most companies use few vendors; outliers can be identified by comparing against known vendors and valid OUIs (e.g., <https://standards-oui.ieee.org> or <https://github.com/wireshark/wireshark/-/blob/365285957876149c959004a96d24db8a07d30/manuf>).
- **802.1X Port Authentication using x509 certificates**—Only devices with a valid certificate can connect to the corporate network.
- **Dynamic Host Configuration Protocol (DHCP)**—Fingerprinting, to determine for example the operating system, device type and vendor.
- **Active Directory to find authorized devices joined to the domain**—Can be correlated with DHCP logs to tag hostnames that exist in Active Directory as authorized. This can be time consuming to set up and expensive to maintain.

NAC may not work in all segments of the network; other forms of discovery are therefore likely necessary to supplement it.

Device Discovery

Asset Lists

Fields that are useful to include in an asset inventory:

- **Business owner**—Person assigned the device
- **Device purpose**—Reason asset was assigned
- **IP address**—Pulled directly from device, or via an active scan or DHCP logs
- **Device type**—Based on endpoint, active scan or AD information
- **Device name**—Based on endpoint, active scan, DHCP logs or AD information
- **Agent presence**—Is an agent installed on the device and active
- **Domain membership**—Active Directory information
- **Criticality of asset**—Used to prioritize alerts and actions

Baselining Assets

Establish a known-good state for assets that can be used as a comparison. This can be static or continuously updated, but should be as complete as possible. Items that should be added to the baseline include:

- Type and amount of network traffic
- Type and number of logs generated
- System resource utilization
- Access times to systems and length of access
- System process count
- Installed software count and type
- Persistence mechanisms
- Certificate stores
- Hosts file that allows a system to override a DNS name record
- Network routing tables. Only under unauthorized circumstances will systems have multiple gateways
- Status of security software
- Local users and groups that exist

DNS

Common DNS Record Types

RECORD TYPE	DESCRIPTION
A	Domain name to IPv4 address
AAAA	Domain name to IPv6 address
CNAME	Alias to A record (e.g., www.sans.org to sans.org)
MX	Maps domain to email server
NS	Designate the domain's authoritative DNS server
PTR	IP address to domain name (for reverse lookups)
SOA	Administrative domain information. (e.g., refresh interval for secondary to pull records from primary DNS server; interval to retry pull if it fails, etc.)
TXT	Sends text over DNS – special purposes (i.e., email authentication, DKIM, or sender approval, SPF)

Useful DNS Response Fields

RECORD TYPE	DESCRIPTION
Query name	Domain name being queried
Query type	DNS record requested
TTL	Time to live—duration of time to cache the response
Data length	Size of resource data
Type	Record type (commonly NS)
RDATA	The authoritative nameserver
DNS response codes	0 (no error), others (indicating some error)
Frequency score	Entropy test for how random a field is (typical example is a URL's frequency)
Parent domain	High-level domain name (e.g., google.com in mail.google.com)
Child domain	Domains below parent domain (e.g., mail in mail.google.com)
Domain lengths	Longer lengths may be indicative of suspicious domains
Domain age	New domains are often used by attackers
Geo-information	Location information can aid in identifying suspicious domains

User Monitoring

Three main categories of user monitoring:

- **Allow lists**—Look for all user events that are not specifically allowed.
- **Deny lists**—Look for known bad events generated by a user.
- **Anomaly-based monitoring**—Understand and learn users' habits to flesh out what a deviation looks like. Users tend to fall into patterns of activity, for example in terms of device type, application usage, location, and work hours. This can be used to search for anomalies.

A combination of these approaches should be used.

Look for evidence of account sharing, with user logs on different systems or in different locations in close proximity.

This can show all connections to or from certain subnets, which can then be used to identify what firewall rules are needed and forecast potential issues.

Flow data can be either unidirectional or bidirectional:

- **Unidirectional** flows track sessions based on one direction only. Two logs would be generated for a session between two systems; one from source to destination, the other from destination to source.
- **Bidirectional** combines sessions using both directions

Flow

It samples one out of every X packets and is often done on a per-Ethernet port basis on switches—can sample Layer 2 traffic.

Flow Data for Asset Identification

SERVICE	PORT(S)
FTP	TCP 21
SSH	TCP 22
File servers (SMB, CIFS)	UDP 137, 138 and TCP 139, 445
Domain Controllers/LDAP	TCP 389 and 636
Web Servers	TCP 80 and 443
Microsoft SQL	TCP 1433
Oracle MySQL	TCP 3306
Remote Desktop	TCP 3389
Oracle Database	TCP 1521, 1630

CIS Critical Security Control #2 focuses on knowing what software is running on an authorized device, or more specifically, knowing and controlling authorized vs. unauthorized applications.

This can be achieved using:

- **Application control software**—Free and commercial tools are available.
 - AppLocker is built into Windows, allows or blocks software based on path, hash, or publisher, and can log to the Windows Event Log.
 - Sysmon includes granular capabilities to include or exclude events.
- **Long Tail Analysis**—Corporate systems are likely to share common software, so the volume of occurrences can be used to sort Most Frequently Occurring (MFO) software as likely authorized, and Least Frequently Occurring (LFO) software as of potential interest.
 - The more machines analyzed, the more accurate the data.
 - Tends to work better on desktops than servers

Built-in System Log Files

OS	LOG FILES
Windows	Windows Event Logs: C:\Windows\System32\winevt\Logs* • Windows 2003/XP and earlier use Event Log format (EV1) • Windows 2008/Vista+ use XML Event Log format (EVTX) - Supports up to 32,766 bytes • Windows 2000+ supports Event Tracing for Windows (ETW) to generate Event Trace Logs - When viewing trace logs, <i>you must sometimes first disable tracing to be able to view the logs</i> - Note: Turning tracing back on clears the logs Windows Firewall —logging is disabled by default: • Can be configured to log to the Event Log by enabling settings in the Object Access and Policy Change audit policies: - <i>Audit Filtering Platform Connection</i>—Logs connection attempts, local port binds and applications or services listening over a network port—the volume of events can be very high if this is enabled so be granular - <i>Audit Filtering Platform Packet Drop</i>—Logs at the packet level, so much more likely to have repetitive entries - <i>Audit Filtering Platform Policy Change</i>—Logs changes to the Windows Filtering Platform (WFP); an API collection that filters network traffic and enforces security rules • <i>Audit MPSSVC Rule-Level Policy Change</i>—MPSSVC.exe is the Microsoft Protection Service, so this setting reports changes to specific firewall rules and offers enhanced configuration granularity • Can be configured to log to a text-based log file, default path is %systemroot%\system32\logfiles\firewall\firewall1.log - To enable: Local Security Policy → Windows Defender Firewall with Advanced Security → <Domain Profile Public Profile Private Profile> → Logging → Customize → Unlick "Not Configured" and select the desired log file - Reading this file requires administrator privileges
Linux	Authentication log , including successful and failed logons: /var/log/auth.log • Each log entry includes: timestamp (mmmm dd hh:mm:ss), source system, source process, and the actual log message Global system log , including kernel, daemon, and other messages: /var/log/syslog • Each log entry includes: RFC 5424 format timestamp, source system, facility value, severity level, priority, syslog version, and the actual log message • Priority is a calculation that takes facility (0–23), multiplies by 8, then adds severity (0–7) • Message consistency is almost non-existent - Syslog over UDP is often limited to 1024 bytes (RFC 3164) - Standard MTU is usually 1500 bytes - Syslog over TCP is often limited to 4096 bytes • When syslog is used, a configuration file (e.g., /etc/syslog.conf) specifies facility and severity levels • Syslog messages sent over network store facility and severity in the computed PRI field Audit log , including system calls, file/directory access, and network connection events: /var/log/audit/audit.log • Each record consists of <i>name=value</i> pairs separated by white space or a comma • type—What triggered the message • msg—Unix timestamp and a unique record ID in the format <i>audit(time_stampID)</i> • Additional fields depend on the type value • A configuration file (/etc/audit/audit.conf) is used to set buffering, log rotation and retention, logging locations, and event filtering • A list of audit rules may exist (/etc/audit/audit.rules) upon which to trigger alerts Global messages (general activity): /var/log/messages • Log entries follow the format <timestamp> <host> <process[pid]>: message - Each log entry includes: timestamp, host system, source of message, and the actual log message Boot time events: /var/log/boot.log • Text-based log containing entries related to system and service start Kernel messages (often used for troubleshooting): /var/log/kern.log • Log entries follow the format <timestamp> <host> <source>: message - Each log entry includes: timestamp, host system, source of message, and the actual log message - View kernel logs on a live system using the journalctl or dmesg commands Scheduled task events: /var/log/cron.log • Log entries follow the format <timestamp> <host> <source[pid]>: (user) message - CMD <command> within the message shows the command that will run Events related to su or sudo access: /var/log/secure • Log entries follow the format <timestamp> <host> <process[pid]>: message

Network Monitoring

NetFlow Data

Monitors connections based on a 7-tuple design. As long as packets have an exact match, they will be monitored as one flow. NetFlow has 100% visibility into IP-based traffic. However, it cannot see Layer 2 traffic.

The seven tuples of NetFlow are:

1. Input logical interface (ifindex)
2. Source IP Address
3. Destination IP Address
4. Source Port
5. Destination Port
6. Layer 3 Protocol type
7. Type of Service byte

Detecting Malicious Connections

- **Tagging**—If tagging is in place, flow data can be used for some great detection capabilities, such as:
 - Workstation-to-workstation traffic: Tags of "source_workstation" and "destination_workstation"
 - Unauthorized server: Tags for certain protocols, such as NTP or DNS, where this should not be present
 - Outbound connections from servers, outside of expected, well-defined use cases
 - Compliance: Privileged rights use, PCI, or PHI, as well as critical or sensitive assets

Software Discovery

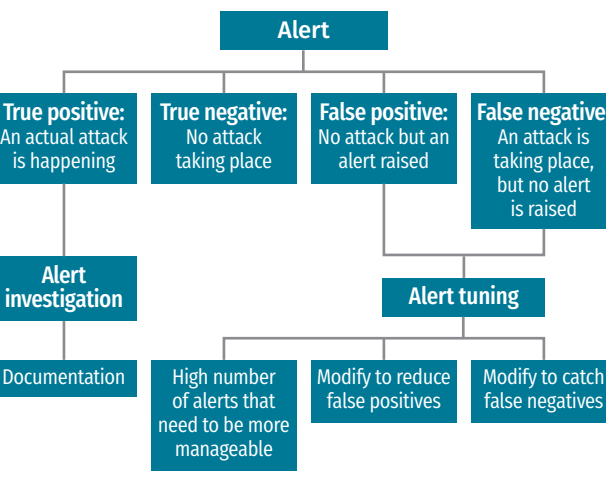
- **Command Line Logging**—Additional logging for PowerShell commands can be enabled.
 - By default, Windows does not include command line parameters in PowerShell command logging. Enable this in: **Group Policy Editor** → **Computer Configuration** → **Administrative Templates** → **System** → **Audit Process Creation** → **Include command line in process creation events**
 - Starting with PowerShell v3, module logging is supported, which can be enabled in: **Local Computer Policy** → **Computer Configuration** → **Administrative Templates** → **Windows Components** → **Windows PowerShell** → **Turn on Module Logging** → **Show** → *
 - PowerShell v5 introduced script block logging, which generates a log for each block of code executed, at the time of execution. This means that decoded commands are recorded. This can be enabled in: **Local Computer Policy** → **Computer Configuration** → **Administrative Templates** → **Windows Components** → **Windows PowerShell** → **Turn on PowerShell Script Block Logging** → **Enabled**
 - Do not select to log start/stop events unless explicitly needed, as it may be too verbose.

- **Top connections**—Look for the top source and destination IP addresses based on number of connections. Spikes can be indicative of command-and-control or exfiltration.
- **Outbound transfers**—Monitor outbound uploads exceeding certain limits or to unusual destinations. Large outbound transfers should only be taking place to authorized sites.
- **Abnormal protocol use**—Analyze upload compared to download traffic per host and protocol. Compare the upload/download ratio to expected values. This is still valuable even if all the data is encrypted.
- **Compare like systems**—Similar systems should have a similar footprint—outliers should be investigated.
- PowerShell v5 introduced transcription logging, which contains both commands entered as well as their corresponding output, to a file. Enabled this in: **Local Computer Policy** → **Computer Configuration** → **Administrative Templates** → **Windows Components** → **Windows PowerShell** → **Turn on PowerShell Transcription**
- Optionally set the output directory (defaults to the user's My Documents folder). The checkbox for "Include invocation headers" will record additional information, such as the timestamps of each command.
- Adversaries may try to downgrade PowerShell to an older version to avoid these features. Downgrade attacks may be detected by identifying event ID 400 in the Windows PowerShell channel and looking for an *Engine version less than five*.

Kusto Query Language (KQL) Cheatsheet

- Kusto Query Language (KQL) is used by security solutions (like Sentinel, Defender XDR and Azure Monitor) but also products such as Azure Data Explorer, Microsoft Fabric, and Azure Resource Graph.
- Start with the tabular dataset
 - Example: *I take 5*
 - Display a table's structure information with "getschema"
 - Example: *I getschema*
 - Search for a value contained in the query using "contains"
 - Example: *I contains "System32"*
 - Use "has_all" and "has_any" options to search for multiple values using logical AND or logical OR
 - Example: *AuditLogs | where OperationName has_all "add","member to role","completed") | where OperationName has_any("timebound","permanent")*
 - Use "datetime" to denote a start and end date for the query
 - Example: *I datetime(2025-03-01)..datetime(2025-04-15)*
 - Use "count" to count the number of rows relating to an argument
 - Example: *I summarize EventCount = count() by src_ip*
 - List distinct values of a column with "distinct"
 - Example: *I distinct src_ip*
 - Use "ago" to provide records that are larger or smaller than a given period of time
 - Example: *I where Timestamp > ago(1d)*
 - d = days; m = minutes; s = seconds
 - The "countif" operator counts occurrences meeting a specific condition
 - Example: *I summarize deletions = countif(FilesDeleted > 10)*
 - Remove a column using the "project-away" operator
 - Example: *I project-away password_hash*

Addressing Alerts



Sigma for SIEM Rules

Sigma rules are written in YAML format. Each rule has a lot of optional metadata fields, but only three are required:

- title
- logsource
- detection

It is highly recommended to populate as many fields as possible, for ease of readability and customization.

Sigma rules have the following possible statuses:

• **Experimental**—A new rule that hasn't been thoroughly tested.

• **Testing**—Limited validation has taken place, but the rule is more stable than an experimental one.

• **Stable**—Widely tested and verified in production.

• **Deprecated**—The rule shouldn't be used. A new rule may exist to supersede it, the detection method is not up-to-date or the threat may no longer be relevant.

• **Unsupported**—The rule isn't maintainable and won't be actively updated.

To make Sigma rules work with a SIEM, they must be converted using PySigma or the Sigma CLI and predefined or custom field mapping.

Sigma rules are a generic format and perfect for sharing. However, a rule that works in one environment may not work well in another.

When new rules are introduced, re-scan your data. This may identify old connections that were malicious, beaconing, or find trends and patterns. This can be resource intensive, so use a dedicated environment, not critical infrastructure.

Case Management Requirements

• **Logs per user**—Effectively an audit trail of what activities an investigator took while working on a case.

• **Escalation**—A way for analysts to escalate cases to different SOC analysts tiers or to another related team.

• **Closure codes**—Ability to close out cases as true positives, false positives, true negatives and false negatives.

• **Isolation of incident information to only the security team**—Although different security operational teams need to be able to work side-by-side, no one in the company should have visibility in a security case.

• **Reporting and metrics**—Think about what fields you need to report on and if that is supported or not.

Other features are nice to have and should also be considered.